BÖLÜM 7: GÜVENLIK VE SIFIR GÜVEN — KRALLIĞI SAVUNMAK

💣 9 dk • DERS 27

Parça 27: Gizli Anahtar Yönetimi, Şifreleme ve Veri Gizliliği

Haber bültenlerine manşet olmadan API anahtarlarını, şifreleri ve müşteri verilerini korumak.

> 🔥 **SAHADAN YAŞANMIŞ KRİZ HİKAYESİ**
>
> Girişimde çalışan bir yazılımcı gece 02:30'da acil bir veritabanı hatasını çözerken kolaylık olsun diye canlı veritabanı şifresini ve AWS master anahtarlarını doğrudan `config.js` dosyasına yapıştırdı. Hatayı çözdü, commit attı ve GitHub'a push'ladı. Ancak şirketin deposu halka açıktı! GitHub commit'lerini tarayan otomatik botlar 8 dakika içinde AWS anahtarlarını yakaladı. Saat 03:15 olduğunda saldırganlar 12 farklı AWS bölgesinde Monero kripto parası kazan 400 adet devasa GPU sunucusu başlatmıştı bile. CTO sabah uyandığında şirket 42.000 dolarlık bir bulut faturasıyla ve çalınmış bir veritabanıyla baş başa kaldı.

Zihniyet Dönüşümü: Kod Yazarlığından Mimarlığa

Gizli anahtarları kaynak kodda tutmak veya git deposuna commit'lemek, evinizin anahtarını sokak kapısının üzerine bantlamaktan farksızdır. Git geçmişi kalıcıdır. Bir mimar; anahtarların çalışma anında güvenli bir kasadan dinamik olarak enjekte edildiği, otomatik olarak döndürüldüğü (rotation) ve verinin hem beklemede hem de taşınırken Zarf Şifreleme (Envelope Encryption) ile korunduğu sistemler tasarlar.

Temel Mimari İlkeler ve Zihinsel Modeller

Gizli Anahtar Yönetim Seviyeleri

- **Seviye 0 (İntihar):** Kodun içinde veya git'e atılan `.env` dosyalarında tutmak.
- **Seviye 1 (Temel):** CI/CD ortam değişkenleriyle dağıtım anında enjekte etmek.
- **Seviye 2 (Modern Standart):** Özel Anahtar Kasaları (HashiCorp Vault, AWS Secrets Manager). Anahtarlar çalışma anında IAM rolüyle dinamik çekilir.
- **Seviye 3 (Sıfır Güven):** Geçici Dinamik Anahtarlar. Kasa veritabanında sadece 60 dakika geçerli geçici bir kullanıcı açar ve süre bitince iptal eder.

Zarf Şifreleme (Envelope Encryption) ve KMS

10 GB'lık veriyi ağ üzerinden şifrelemek yavaştır. Zarf şifreleme iki katman kullanır:

1. Yerel bir **Veri Şifreleme Anahtarı (DEK)** veriyi yerel olarak anında şifreler.
2. Bulut KMS servisi sadece bu DEK anahtarını ana anahtarla (KEK) şifreler.
3. Verinin yanında sadece şifrelenmiş DEK saklanır.

Kaçınılması Gereken Anti-Pattern'ler ve Tuzaklar

- **Docker İmajına Şifre Gömmek:** Dockerfile katmanlarına `ENV DB_PASS=gizli123` yazıp imajı çekebilen herkese şifreyi hediye etmek.
- **Loglara Hassas Veri Basmak:** Kullanıcı şifrelerini veya kredi kartlarını log dosyalarına yazdırmak (`logger.info('Kullanıcı: ' + user)`), Datadog'u KVKK suç mahalline çevirmek.
- **Dönmeyen Anahtarlar:** Aynı veritabanı şifresini işten ayrılan 20 mühendise rağmen 5 yıl boyunca hiç değiştirmeden kullanmak.

🎯 MİMARIN EYLEM PLANI: BU HAFTAKİ SOMUT ADIMLAR

- **1. Adım:** Git geçmişinde sızmış şifreleri bulmak için hemen Trufflehog veya git-secrets çalıştır.
- **2. Adım:** Statik konfigürasyon şifrelerini merkezi bir kasaya (AWS Secrets Manager / Vault) taşı.
- **3. Adım:** Loglama katmanına otomatik maskeleme ekleyerek kredi kartı, şifre ve kimlik numaralarını loglardan temizle.

Mimari Çıkarımlar ve Hile Tablosu

- Kaynak kod sadece mantık içindir, asla sır barındırmaz. Git'e girmiş bir anahtar taviz verilmiş sayılır.
- Otomatik anahtar döndürme (rotation) anahtar sızıntılarına karşı en büyük kalkanınızdır.
- Hassas müşteri verilerini log sınırında maskeleyin; log sisteminiz veri sızıntı kaynağı olmasın.

🎙️ UDEMY & NOTEBOOKLM TARTIŞMA VE ÖDEV SORUSU

Ders Değerlendirmesi ve Ödev: Kod tabanınızda `password`, `secret` veya `apiKey` kelimelerini aratın. Sabit değerler var mı? Canlı veritabanı şifrenizi şu an değiştirmek isteseniz bu ne kadar sürer?